

TRIỂN KHAI HỆ THỐNG WAZUH SIEM

Giai đoạn 2: Giám sát Log, thực hiện các kịch bản tấn công và phát hiện xâm nhập

Module 1: File Integrity Monitoring (FIM).

1.1 Bật File Integrity Monitoring (FIM) trên máy Agent.

Cấu hình FIM trên Agent để giám sát các thư mục quan trọng:

Trên máy Windows agent truy cập theo đường dẫn: C:\Program Files (x86)\ossec-agent. Mở file ossec.conf bằng quyền Administrator để thêm cấu hình

```
# Trên Agent (Windows):  
<syscheck>  
  <frequency>300</frequency>  
  <directories check_all="yes">C:\Users\Public</directories>  
  <directories check_all="yes">C:\Windows\System32</directories>  
  <directories check_all="yes">C:\Program Files</directories>  
</syscheck>
```

Trên máy Linux Agent sử dụng câu lệnh: `sudo nano /var/ossec/etc/ossec.conf` để chỉnh sửa file cấu hình của Wazuh agent.

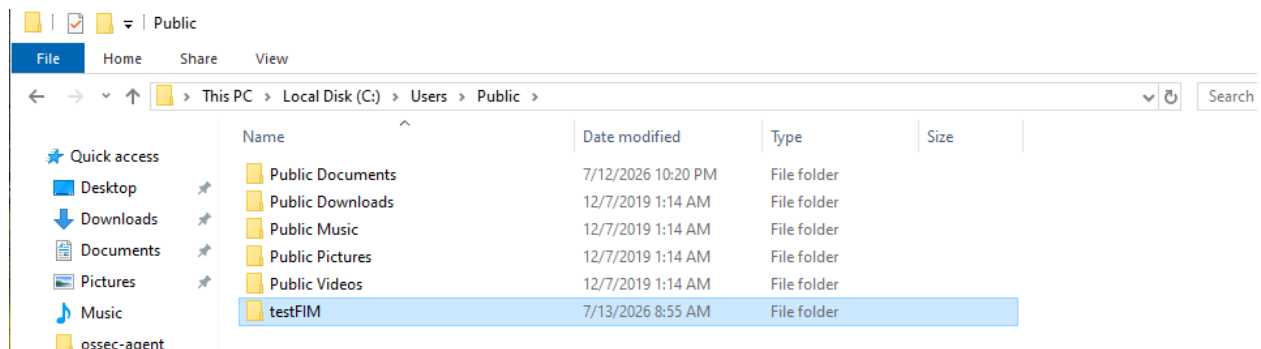
```
# /var/ossec/etc/ossec.conf trên Agent (Linux):  
<syscheck>  
  <frequency>300</frequency> <!-- Quét mỗi 5 phút -->  
  <directories check_all="yes" realtime="yes">/var/www/html</directories>  
  <directories check_all="yes" realtime="yes">/tmp</directories>  
  <directories check_all="yes">/etc</directories>  
  <directories check_all="yes">/usr/bin</directories>
```

```
</syscheck>
```

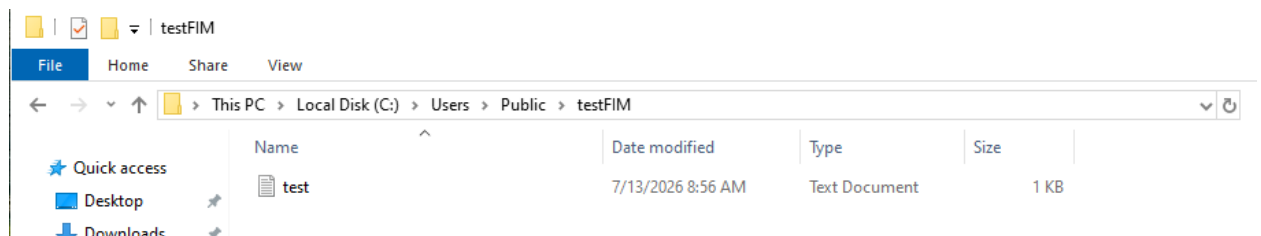
Sau đó restart lại dịch vụ Wazuh agent bằng câu lệnh: Restart-Service WazuhSvc trên Windows agent và Sudo systemctl restart wazuh-agent trên Linux agent. Việc thêm lệnh để tạm thời bật giám sát trong thời gian thực, tính năng này cho phép Wazuh theo dõi các thay đổi đối với các tệp ở trong các thư mục được chỉ định và tạo cảnh báo nếu có bất kỳ thay đổi nào được phát hiện

Ở máy agent windows 10 tiến hành tạo 1 thư mục mới và 1 file mới trong thư mục đó tiến hành sửa nội dung bên trong file và kiểm tra log ghi nhận bên Wazuh Server.

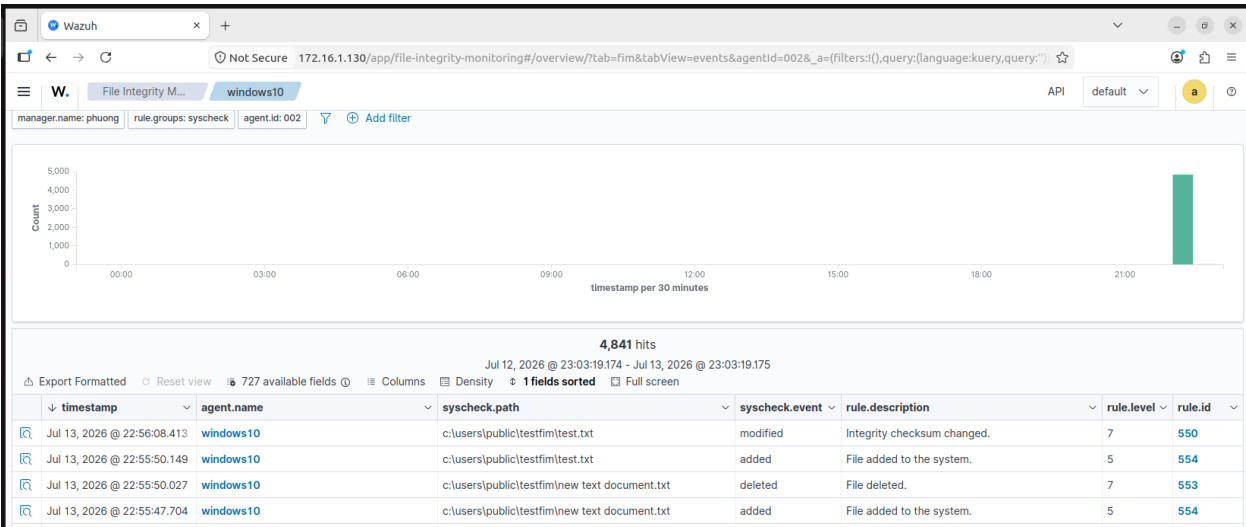
Tạo 1 thư mục mới là “testFIM” trong thư mục gốc C:\Users\Public



Vào trong thư mục vừa tạo, tạo thêm 1 file test.txt.



Quay về Wazuh Server và refresh lại dashboard chọn vào file integrity monitoring.



Xem chi tiết Log:

Document Details		View surrounding documents	View single document
TableJSON			
t _index	wazuh-alerts-4.x-2026.07.13		
t agent.id	002		
t agent.ip	172.16.1.129		
t agent.name	windows10		
t decoder.name	syscheck_integrity_changed		
t full_log	File 'c:\users\public\testfim\test.txt' modified Mode: realtime Changed attributes: size,mtime,md5,sha1,sha256 Size changed from '0' to '8' Old modification time was: '1783958147', now it is '1783958168' Old md5sum was: 'd41d8cd98f00b204e9800998ecf8427e' Now md5sum is: 'hch0a67182a1a57a12h605fa8dfc85a'		
t id	1783958168.13464973		
t input.type	log		
t location	syscheck		
t manager.name	phuong		
t rule.description	Integrity checksum changed.		
# rule.firedtimes	780		
t rule.gdpr	II_5.1.f		
t rule.gpg13	4.11		
t rule.groups	ossec, syscheck, syscheck_entry_modified, syscheck_file		

- decoder.name: syscheck_integrity_changed

→ Loại sự kiện: checksum của một file đã thay đổi.

- syscheck.event: modified

→ Thao tác: file được sửa (modify).

- syscheck.mode: realtime

→ Được phát hiện ngay tức thì (bằng event-based), không phải quét định kỳ.

full_log Wazuh liệt kê chi tiết:

- Kích thước tăng từ 3 byte lên 8 byte.
- Thời gian chỉnh sửa (mtime) thay đổi theo timestamp UNIX.
- Checksum (MD5, SHA-1, SHA-256) đều đổi, minh chứng file đã bị sửa nội dung.

Alert này cho thấy chức năng Integrity Monitoring (FIM) của Wazuh đang hoạt động chính xác: phát hiện thay đổi file ngay lập tức, sinh alert với thông tin chi tiết về checksum và timestamp, giúp bạn nhanh chóng xác định xem đó là thay đổi “chính đáng” hay dấu hiệu tấn công

1.2 Tích hợp VirusTotal cho FIM.

VirusTotal là dịch vụ phân tích mối đe dọa của Google, cho phép kiểm tra file hash, URL và địa chỉ IP với hơn 70 engine antivirus. Wazuh hỗ trợ tích hợp sẵn với VirusTotal API.

Lấy API Key từ VirusTotal.

Cần đăng ký tài khoản miễn phí tại [virustotal.com](https://www.virustotal.com):

- Truy cập <https://www.virustotal.com> và đăng ký tài khoản
- Vào Profile > API Key, sao chép API key
- Lưu ý: Tài khoản miễn phí giới hạn 4 request/phút và 500 request/ngày
- Đối với môi trường lab, giới hạn này là đủ dùng

Ta có API Key của Virustotal là

“c6c8443577d4acb6898206e1eb78c9670c8c082a87431b187801acf748ebb1f4”

Cấu hình tích hợp trên Wazuh Server

Trên máy Wazuh Server truy cập file cấu hình /var/ossec/etc/ossec.conf

```
<ossec_config> <!-- Đoạn code cấu hình tích hợp VirusTotal -->
<integration>
<name>virustotal</name>
<api_key>c6c8443577d4acb6898206e1eb78c9670c8c082a87431b187801acf748ebb1f4
</api_key>
<group>syscheck</group>
<alert_format>json</alert_format>
</integration>
</ossec_config>
```

Sau đó restart lại Wazuh manage.

Cơ chế hoạt động khi được tích hợp thêm Virustotal.

Khi Wazuh FIM (File Integrity Monitoring) phát hiện file bị thay đổi hoặc thêm mới, Wazuh sẽ:

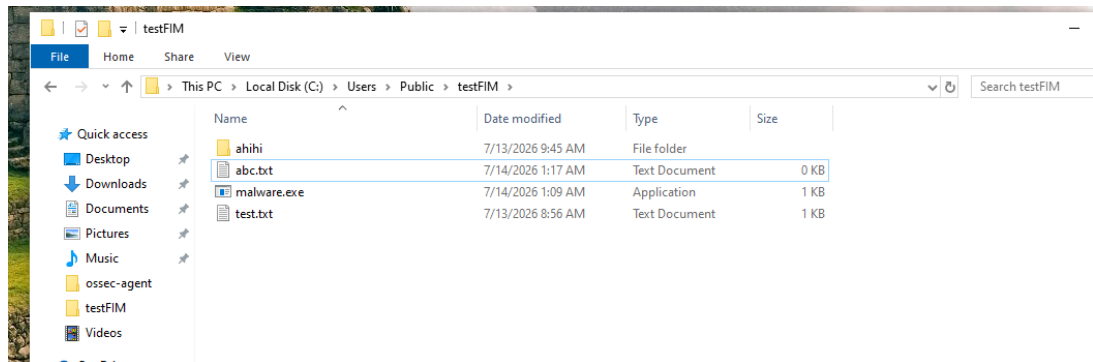
1. Lấy giá trị hash (MD5/SHA1/SHA256) của file từ alert syscheck
2. Gửi hash đến VirusTotal API để kiểm tra
3. Nhận kết quả: số engine phát hiện độc hại / tổng số engine
4. Tạo alert mới với thông tin từ VirusTotal (rule 87105–87107)

Sau khi cấu hình xong ta sẽ tiến hành kiểm tra và phát hiện file độc hại trên máy agent.

Để kiểm tra xem hệ thống có tự động bắt được mã độc hay không, chúng ta sẽ dùng file **EICAR Anti-Malware Test File** (Đây là một chuỗi ký tự tiêu chuẩn được các hãng bảo mật quy ước giả lập làm mã độc, hoàn toàn an toàn cho máy tính cá nhân).

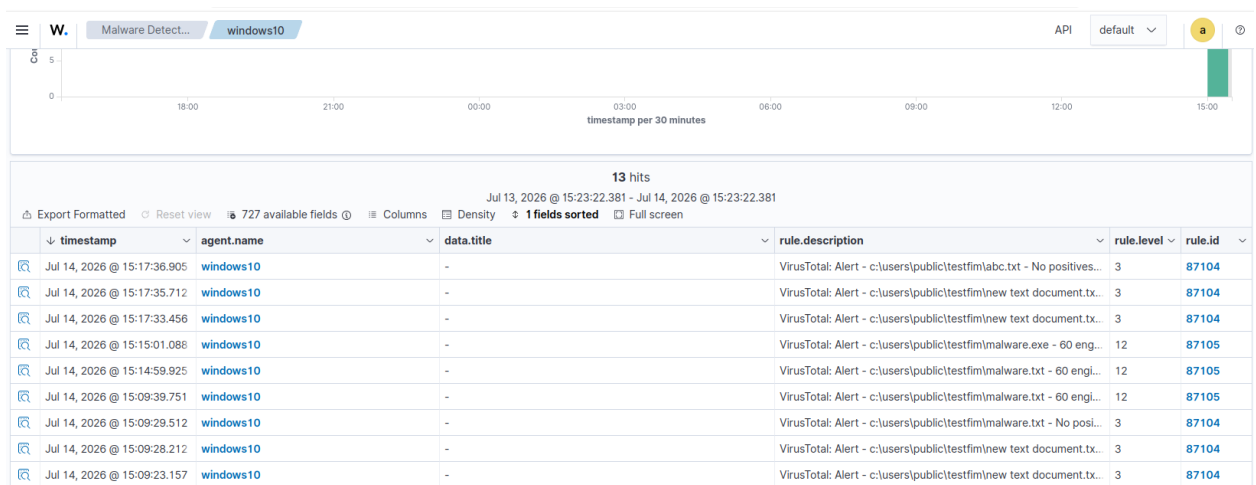
- Trên máy Windows Target, truy cập vào thư mục C:\Users\Public

- Tạo một file text mới tên là malware_test.txt.
- Dán chuỗi ký tự sau vào file và bấm Lưu (Save):
X5O!P%@AP[4\PZX54(P^7CC)7}\$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!\$H+H*
- Đổi đuôi file từ .txt thành .exe (Ví dụ: malware_test.exe).



Kiểm tra kết quả trên Wazuh Dashboard.

Truy cập vào Malware Detection → Event



Xem chi tiết log:

Document Details

View surrounding documents

View single document

Table JSON

_index	wazuh-alerts-4.x-2026.07.14
agent.id	002
agent.ip	172.16.1.129
agent.name	windows10
data.integration	virustotal
data.virustotal.found	1
data.virustotal.malicious	1
data.virustotal.permalink	https://www.virustotal.com/gui/file/275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f/detection/f-275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f-1784016253
data.virustotal.positives	60
data.virustotal.scan_date	2026-07-14 08:04:13
data.virustotal.sha1	3395856ce81f2b7382dee72602f798b642f14140
data.virustotal.source.alert_id	1784016898.184102
data.virustotal.source.file	c:\users\public\testfim\malware.txt
data.virustotal.source.md5	44d88612fea8a8f36de82e1278abb02f
data.virustotal.source.sha1	3395856ce81f2b7382dee72602f798b642f14140
data.virustotal.total	63
decoder.name	json

Các rule VirusTotal cần chú ý:

- 87105: VirusTotal - Alert (file được phát hiện độc hại)
- 87106: VirusTotal - No alert (file sạch)
- 87107: VirusTotal - Error (API lỗi hoặc hết quota)

Alert sẽ chứa thông tin:

- data.virustotal.positives: Số engine phát hiện
- data.virustotal.total: Tổng số engine
- data.virustotal.permalink: Link chi tiết trên VT

Document Details		View surrounding documents	View single document
data.virustotal.source.md5	44d88612fea8a8f36de82e1278abb02f		
data.virustotal.source.sha1	3395856ce81f2b7382dee72602f798b642f14140		
data.virustotal.total	63		
decoder.name	json		
id	1784016899.187436		
input.type	log		
location	virustotal		
manager.name	phuong		
rule.description	VirusTotal: Alert - c:\users\public\testfim\malware.txt - 60 engines detected this file		
# rule.firedtimes	2		
rule.gdpr	IV_35.7.d		
rule.groups	virustotal		
rule.id	87105		
# rule.level	12		
rule.mail	true		
rule.mitre.id	T1203		
rule.mitre.tactic	Execution		
rule.mitre.technique	Exploitation for Client Execution		
rule.pci_dss	10.6.1, 11.4		
timestamp	Jul 14, 2026 @ 15:14:59.925		

Modules 2: Kịch bản tấn công thực tế.

Kịch bản 1: Tấn công Brute-force SSH. Sử dụng máy tấn công kali linux nhắm mục tiêu vào máy Linux agent. Trên máy kali linux sử dụng công cụ Hydra để tấn công ssh vào máy linux agent sử dụng câu lệnh

Từ Kali linux sử dụng câu lệnh:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://172.16.1.135
```

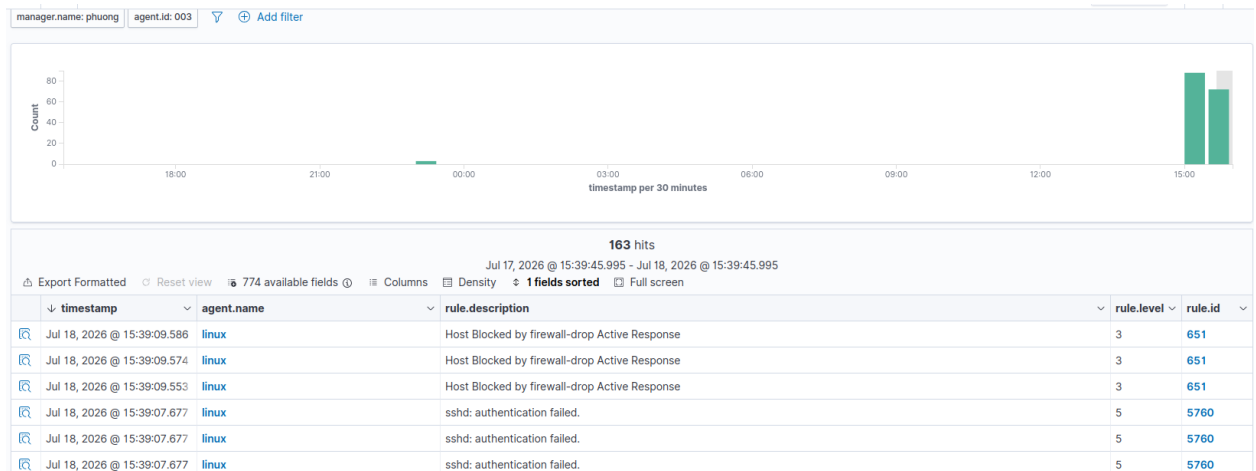


```
kali@kali: ~/Desktop
Session Actions Edit View Help

(kali@kali)-[~/Desktop]
$ hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://172.16.1.135
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 04:
27:39
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking ssh://172.16.1.135:22/
```

Quay trở lại máy Wazuh-manage để kiểm tra các event đã xảy ra. Truy cập vào phần Threat Hunting→Event.



Ta có thể thấy các rule.id 5760 được dùng để phát hiện các sự kiện xác thực SSH thất bại (SSH Authentication Failed) trên hệ điều hành Linux.

Xem chi tiết Event:

Document Details

[View surrounding documents](#)[View single document](#)

Table JSON

† _index	wazuh-alerts-4.x-2026.07.18
† agent.id	003
† agent.ip	172.16.1.135
† agent.name	linux
† data.dstuser	kali
† data.srcip	172.16.1.134
† data.srcport	33122
† decoder.name	sshd
† decoder.parent	sshd
† full_log	Jul 18 08:39:06 kali sshd-session[13865]: Failed password for kali from 172.16.1.134 port 33122 ssh2
† id	1784363947.270342
† input.type	log
† location	journalld
† manager.name	phuong
† predecoder.hostname	kali
-	
† predecoder.hostname	kali
† predecoder.program_name	sshd-session
† predecoder.timestamp	Jul 18 08:39:06
† rule.description	sshd: authentication failed.
# rule.firedtimes	15
† rule.gdpr	IV_35.7.d, IV_32.2
† rule.gpg13	7.1
† rule.groups	syslog, sshd, authentication_failed
† rule.hipaa	164.312.b
† rule.id	5760
# rule.level	5
🔊 rule.mail	false
† rule.mitre.id	T1110.001 T1021.004
† rule.mitre.tactic	Credential Access, Lateral Movement
† rule.mitre.technique	Password Guessing, SSH
† rule.nist_800_53	AU.14, AC.7
† rule.pci_dss	10.2.4, 10.2.5
† rule.tsc	CC6.1, CC6.8, CC7.2, CC7.3
📅 timestamp	Jul 18, 2026 @ 15:39:07.677

Thông tin cảnh báo bao gồm:

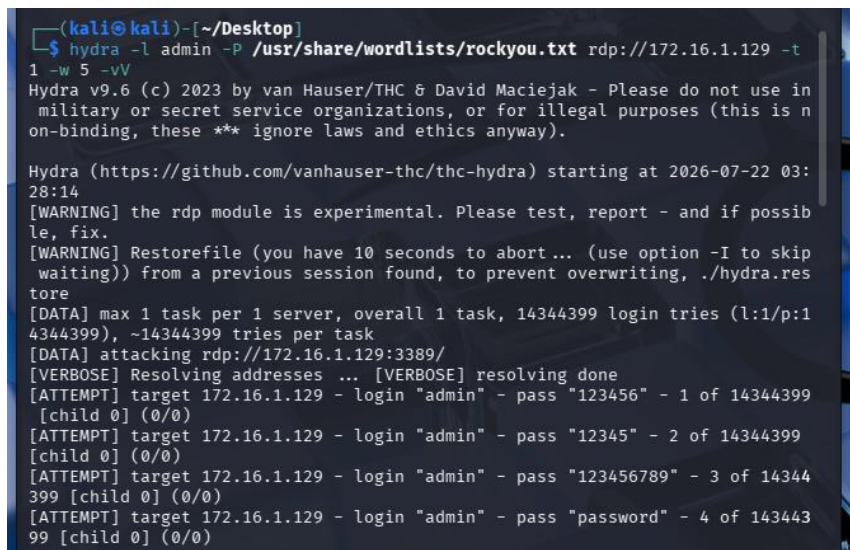
- Rule ID: 5760

- Mức độ cảnh báo (Level): 5
- Mô tả: sshd: authentication failed.
- Địa chỉ IP nguồn (Source IP): 172.16.1.134
- Tên tài khoản được sử dụng: kali
- Thời gian xảy ra sự kiện

Kịch bản 2: Tiếp tục sử dụng công cụ Hydra trên máy kali linux để Tấn công Brute-force RDP nhằm mục tiêu vào máy Windows agent.

Từ Kali linux sử dụng câu lệnh:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt rdp://172.16.1.129 -t 1 -w 5 -vV
```



```
(kali@kali)-[~/Desktop]
$ hydra -l admin -P /usr/share/wordlists/rockyou.txt rdp://172.16.1.129 -t
1 -w 5 -vV
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-22 03:
28:14
[WARNING] the rdp module is experimental. Please test, report - and if possib
le, fix.
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
waiting)) from a previous session found, to prevent overwriting, ./hydra.res
tore
[DATA] max 1 task per 1 server, overall 1 task, 14344399 login tries (l:1/p:1
4344399), ~14344399 tries per task
[DATA] attacking rdp://172.16.1.129:3389/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 172.16.1.129 - login "admin" - pass "123456" - 1 of 14344399
[child 0] (0/0)
[ATTEMPT] target 172.16.1.129 - login "admin" - pass "12345" - 2 of 14344399
[child 0] (0/0)
[ATTEMPT] target 172.16.1.129 - login "admin" - pass "123456789" - 3 of 14344
399 [child 0] (0/0)
[ATTEMPT] target 172.16.1.129 - login "admin" - pass "password" - 4 of 143443
99 [child 0] (0/0)
```

Quay trở lại máy Wazuh manager để kiểm tra các event đã xảy ra.

Export FormattedReset view808 available fieldsColumnsDensity1 fields sortedFull screen

timestamp	agent.name	rule.description	rule.level	rule.id
Jul 22, 2026 @ 14:29:08.783	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:29:06.748	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:29:04.717	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:29:02.690	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:29:00.670	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:58.659	windows10	Multiple Windows Logon Failures	10	60204
Jul 22, 2026 @ 14:28:56.624	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:54.593	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:52.577	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:50.561	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:48.561	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:46.684	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:44.653	windows10	Logon Failure - Unknown user or bad password	5	60122
Jul 22, 2026 @ 14:28:42.622	windows10	Multiple Windows Logon Failures	10	60204
Jul 22, 2026 @ 14:28:40.591	windows10	Logon Failure - Unknown user or bad password	5	60122

Ta có thể thấy các rule.id **Rule 60122** (Level 5): Logon Failure - Unknown user or bad password (Đăng nhập thất bại do sai tên người dùng hoặc mật khẩu). **Rule 60204** (Level 10): Multiple Windows Logon Failures (Cảnh báo tổng hợp khi có quá nhiều lần đăng nhập thất bại liên tiếp).

Xem chi tiết Event của rule.id 60122 và 60204:

t id	1784705350.2087923
t input.type	log
t location	EventChannel
t manager.name	phuong
t rule.description	Logon Failure - Unknown user or bad password
# rule.firedtimes	20
t rule.gdpr	IV_35.7.d, IV_32.2
t rule.gpg13	7.1
t rule.groups	windows, windows_security, authentication_failed
t rule.hipaa	164.312.b
t rule.id	60122
# rule.level	5
rule.mail	false
t rule.mitre.id	T1531
t rule.mitre.tactic	Impact
t rule.mitre.technique	Account Access Removal
t rule.nist_800_53	AU.14, AC.7
t rule.pci_dss	10.2.4, 10.2.5
t rule.tsc	CC6.1, CC6.8, CC7.2, CC7.3
timestamp	Jul 22, 2026 @ 14:29:10.795

60122

Thông tin cảnh báo bao gồm:

- Rule ID: 60122
- Mức độ cảnh báo (Level): 5
- Mô tả: Logon Failure - Unknown user or bad password
- Địa chỉ IP nguồn (Source IP): 172.16.1.134
- Tên tài khoản được sử dụng: kali
- Thời gian xảy ra sự kiện

t id	1784705338.2032029
t input.type	log
t location	EventChannel
t manager.name	phuong
t previous_output	{ "win": { "system": { "providerName": "Microsoft-Windows-Security-Auditing", "providerGuid": "{54849625-5478-4994-a5ba-3e3b0328c30d}", "eventId": "4625", "version": "0", "level": "0", "task": "12544", "opcode": "0", "keywords": "0x8010000000000000", "systemTime": "2026-07-22T07:28:55.6478769Z", "eventRecordID": "976", "processID": "664", "threadID": "6476", "channel": "Security", "computer": "DESKTOP-VKU4J4C", "severityValue": "AUDIT_FAILURE", "message": "\\An account failed to log on.\\n\\n\\nSubject: \\n\\n\\nSecurity ID: \\n\\n\\nS-1-0-0\\n\\n\\nAccount N
t rule.description	Multiple Windows Logon Failures
# rule.firedtimes	2
# rule.frequency	8
t rule.gdpr	IV_35.7.d, IV_32.2
t rule.groups	windows, windows_security, authentication_failures
t rule.hipaa	164.312.b
t rule.id	60204
# rule.level	10
rule.mail	false
t rule.mitre.id	T1110
t rule.mitre.tactic	Credential Access
t rule.mitre.technique	Brute Force
t rule.nist_800_53	AU.14, AC.7, SI.4

60204

Thông tin cảnh báo bao gồm:

- Rule ID: 60204
- Mức độ cảnh báo (Level): 10
- Mô tả: Multiple Windows Logon Failures
- Địa chỉ IP nguồn (Source IP): 172.16.1.134

- Tên tài khoản được sử dụng: kali
- Thời gian xảy ra sự kiện

Modules 3: Tích hợp Firewall

Tổng quan giám sát Firewall trong thực tế, firewall là tuyến phòng thủ đầu tiên. Việc tích hợp log firewall vào Wazuh giúp:

- Phát hiện các nỗ lực kết nối bất thường (port scan, connection flood)
- Giám sát thay đổi cấu hình firewall (ai đã thay đổi rule gì, khi nào)
- Tương quan log firewall với các nguồn khác (đăng nhập, web log)
- Tự động chặn IP độc hại qua Active Response

3.1 Sử dụng Iptables để giám sát trên Linux agent

Trên máy linux agent bật logging cho iptables.

```
# Thêm rule log cho kết nối bị chặn:
sudo iptables -A INPUT -j LOG --log-prefix "[IPTABLES-DROP] " --log-level 4
sudo iptables -A INPUT -m state --state INVALID -j DROP

# Log cho các kết nối mới đến port nhạy cảm:
sudo iptables -A INPUT -p tcp --dport 22 -m state --state NEW -j LOG --log-prefix "[SSH-NEW] " --log-level 4
sudo iptables -A INPUT -p tcp --dport 80 -m state --state NEW -j LOG --log-prefix "[HTTP-NEW] " --log-level 4
```

Cấu hình Wazuh Agent đọc log iptables

```
<localfile>
  <log_format>journald</log_format>
  <location>journald</location>
</localfile>
sudo systemctl restart wazuh-agent
```

Kiểm tra log của iptables sử dụng câu lệnh: `sudo dmesg | grep IPTABLES`

```
[ 2867.872823] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44375 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2867.873165] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44376 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2869.831144] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44377 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2869.831597] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44378 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2869.833162] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44379 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2869.835249] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44380 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2869.837573] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44381 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2871.836448] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44382 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
[ 2871.836810] [IPTABLES-DROP] IN=eth0 OUT= MAC=00:0c:29:eb:7c:9a:00:0c:29:f6
:97:ae:08:00 SRC=172.16.1.133 DST=172.16.1.135 LEN=52 TOS=0x00 PREC=0x00 TTL=
64 ID=44383 DF PROTO=TCP SPT=1514 DPT=49311 WINDOW=9667 RES=0x00 ACK URGP=0
```

3.2 Thực hành: Active Response tự động chặn IP qua Firewall

Để nâng cao khả năng phản ứng trước các cuộc tấn công, hệ thống Wazuh được cấu hình tính năng **Active Response** nhằm tự động thực hiện các hành động phòng thủ khi phát hiện các sự kiện bảo mật có mức độ nguy hiểm cao. Trong mô hình này, Active Response được sử dụng để tự động chặn địa chỉ IP của máy tấn công thông qua tường lửa iptables trên máy Linux Agent.

Cấu hình trên Wazuh manager để chặn các địa chỉ IP của máy tấn công

```
<!-- Tự động block IP khi phát hiện brute-force -->
<active-response>
  <command>firewall-drop</command>
```

```

<location>local</location>
<rules_id>5712,5758,2502,5710,5760</rules_id>
<timeout>600</timeout> <!-- Block 10 phút -->
</active-response>

<!-- Tự động block khi VT phát hiện malware -->
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>87105</rules_id>
  <timeout>3600</timeout> <!-- Block 1 giờ -->
</active-response>

```

Sau khi cấu hình xong ta sẽ kiểm tra Active Response hoạt động. Bằng cách thực hiện lại cuộc tấn công brute-force SSH từ máy tấn công kali linux:

1. Từ Kali, tấn công brute-force SSH:

hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://172.16.1.135 -vV t 4

```

kali@kali: ~/Desktop
Session Actions Edit View Help

(kali@kali)-[~/Desktop]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://172.16.1.135 -vV
-t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-20 11:
05:39
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip
waiting)) from a previous session found, to prevent overwriting, ./hydra.res
tore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p
:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.16.1.135:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://root@172.16.1
.135:22
[INFO] Successful, password authentication is supported by ssh://172.16.1.135
:22
[ATTEMPT] target 172.16.1.135 - login "root" - pass "123456" - 1 of 14344399
[child 0] (0/0)
[ATTEMPT] target 172.16.1.135 - login "root" - pass "12345" - 2 of 14344399 [
child 1] (0/0)
[ATTEMPT] target 172.16.1.135 - login "root" - pass "123456789" - 3 of 143443
99 [child 2] (0/0)
[ATTEMPT] target 172.16.1.135 - login "root" - pass "password" - 4 of 1434439

```

2. Từ máy tấn công thử ping đến máy mục tiêu, câu lệnh bị treo trong vòng 10 phút.


```
(kali@kali)-[~/Desktop]
$ ping 172.16.1.135
PING 172.16.1.135 (172.16.1.135) 56(84) bytes of data.
```

3. Kiểm tra Iptables trên máy linux agent xem danh sách các địa chỉ IP bị chặn.
Ta có thể thấy địa chỉ IP:172.16.1.134 của máy tấn công đã bị chặn.

```
(kali@kali)-[~/Desktop]
$ sudo iptables -L INPUT -n | grep DROP
[sudo] password for kali:
DROP      all -- 172.16.1.134      0.0.0.0/0
LOG        all -- 0.0.0.0/0          0.0.0.0/0          LOG flags 0 lev
el 4 prefix "[IPTABLES-DROP] "
DROP      all -- 0.0.0.0/0          0.0.0.0/0          state INVALID
```

4. Xem trên Wazuh manager sẽ xuất hiện các rule.id: 5760 đại diện cho cuộc tấn công ssh và rule.id: 651 đã chặn IP của máy tấn công.

